1.4 The Pillars of AI Governance V1

AI governance can sound abstract until something breaks. The seven pillars below are the dimensions along which AI in healthcare tends to succeed — or fail publicly. For each pillar, we describe the core question it answers, why it matters in a healthcare context, what it looks like in practice, and a real-world example of what happens when the pillar is missing. The goal is a usable mental model, not a vocabulary list.

Pillar 1 — Accountability & Ownership

The core question: Who owns AI decisions, and who is answerable when something goes wrong?

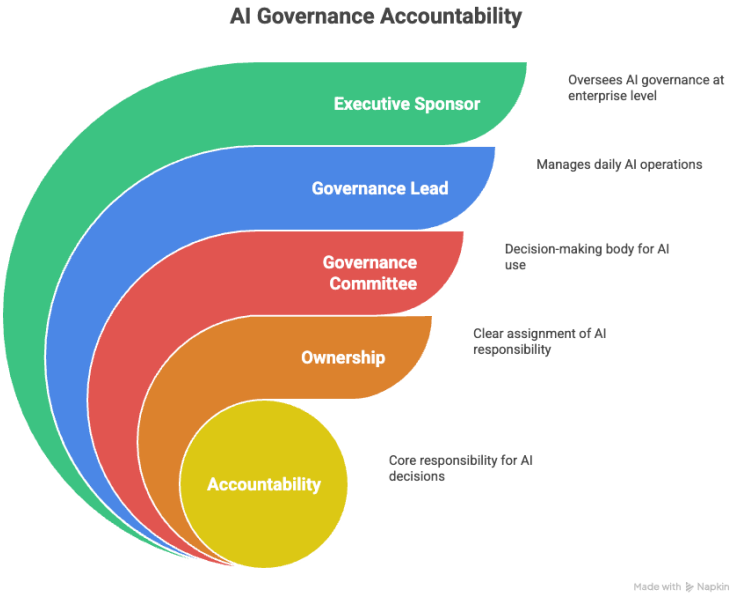
Accountability is the starting point of AI governance. In many healthcare organizations, AI enters through a pilot, a vendor add-on, or a department-level initiative long before ownership is clearly defined. When that happens, decision-making becomes fragmented. Teams may use the tool, support the workflow, or depend on the outputs, but no one is formally responsible for the full lifecycle of the system.

In healthcare, that ambiguity carries real consequences. AI can influence patient triage, documentation, staffing, outreach, billing, and risk prioritization. If a system fails, the organization must already know who has authority to review it, pause it, escalate concerns, and communicate next steps. Accountability, at its core, means answering three questions before an AI system goes live: who approved this, who is monitoring it, and who acts when something goes wrong.

What it looks like in practice: There is a named executive sponsor for AI governance, typically reporting to the CIO, Chief Compliance Officer, or CDO, who owns the program at an enterprise level. There is a working governance lead who manages day-to-day operations. There is a governance committee with actual decision authority, not just advisory input, meaning it can approve, condition, defer, or deny AI use cases, and its decisions are binding on the departments requesting them. Decision rights are documented: who can approve a low-risk use case without committee review, who escalates a medium-risk use case, and who must be in the room for high-risk decisions involving clinical AI or large-scale PHI processing. Escalation paths are clear. When a frontline employee or a department head encounters an AI issue, they know exactly where to take it and how fast a response to expect.

What happens without it: Between 2018 and 2021, the UK's medical device regulator investigated repeated safety concerns about Babylon Health's symptom-checker chatbot, which was then serving tens of thousands of NHS patients. Clinicians documented cases where the chatbot failed to flag likely heart attacks in women while identifying the same symptoms as

potential heart attacks in men, and missed signs of other serious conditions.[1] As concerns mounted, accountability fractured across the vendor, the NHS deployment partner, and the regulator, and no single owner had both the authority and the responsibility to halt use of the tool while the issues were investigated. *The lesson: if no one is named as the owner before something goes wrong, no one owns it when something does.*



Pillar 2 — Transparency & Explainability

The core question: Can you explain how the AI reached its output, and is that explanation sufficient for the context?

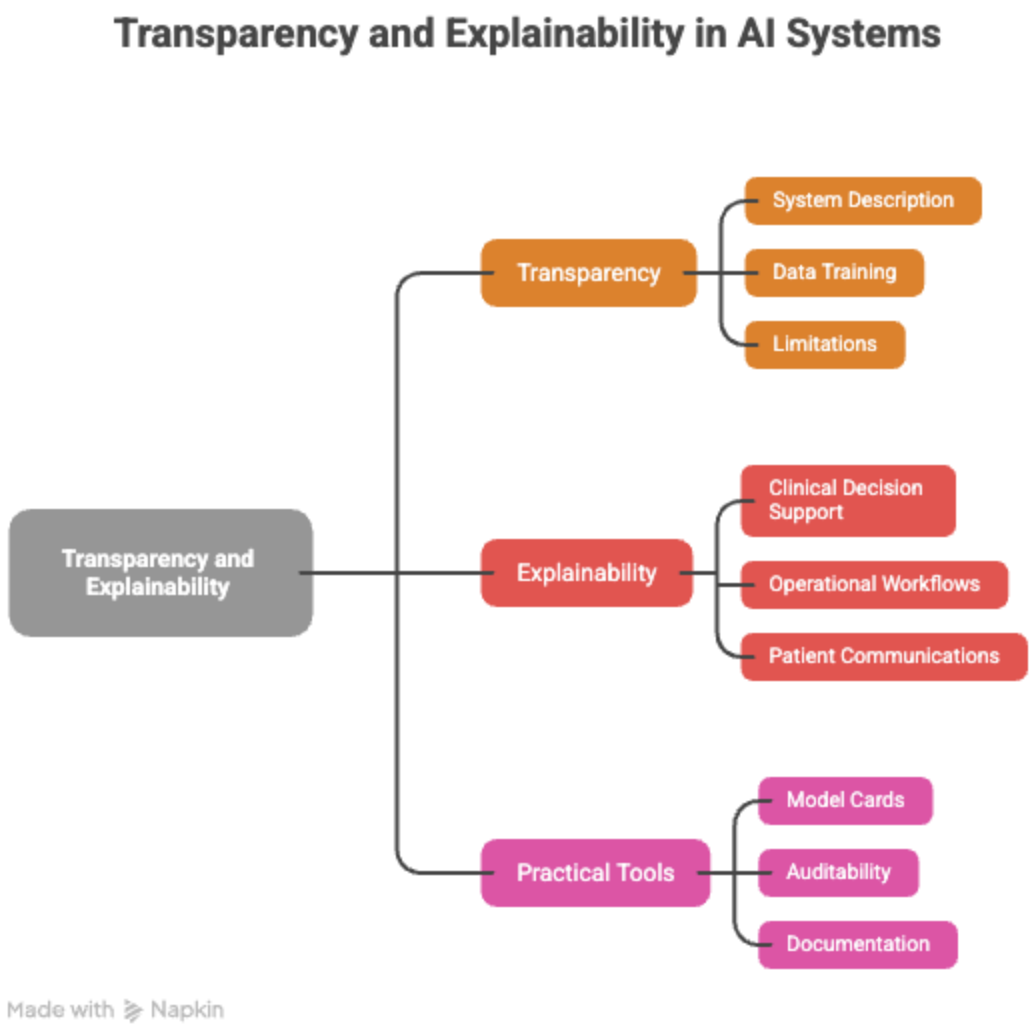
AI systems in healthcare do not operate in isolation. Their outputs feed into clinical decisions, operational workflows, and patient communications. When a physician receives an AI-generated risk score, when a care manager sees a flagged patient, when a billing team acts on an automated recommendation, there is an implicit trust that the output is grounded in something defensible. Transparency means the organization can articulate what the system does, how it arrives at its outputs, and what its known limitations are. Explainability means that articulation is sufficient for the person acting on it. In a clinical setting, a physician needs enough understanding to know when to trust the output and when to override it. In an operational setting, an auditor needs enough documentation to verify that the system behaved as intended. The standard is not the same for every use case, but every use case needs a standard.

What it looks like in practice: Every AI system in production has a documented system description, essentially a "nutrition label," that answers: what does this tool do, what data was it trained on, what are its known limitations, who built it, and when was it last validated. There is a

defined standard for what level of explanation each use case requires, and that standard varies by risk. A marketing copy generator does not need the same level of explainability as a clinical decision support tool. For clinical AI, a physician can trace the reasoning path from input to output, not necessarily the math inside the model, but enough to understand what factors drove the recommendation and to override it with confidence when clinical judgment says otherwise. For operational and business AI, auditability suffices: there is a record of what the system did, why, and what data it used, even if no one needs to explain it to a patient in real time. One of the most practical tools for achieving this is what the AI industry calls a “model card”.

What is a model card? Think of it as a nutrition label for an AI system. Just as a medication label tells you what a drug does, who should use it, and what the known side effects are, a model card documents what an AI tool does, what data it was trained on, who it is intended for, what its known limitations are, and how well it performs across patient populations. The concept was first proposed by Google researchers in 2019 and has since been adopted by the FDA, which now recommends model cards in device labeling for AI-enabled medical devices (see the FDA's January 2025 draft guidance on AI-enabled device software functions, Appendices E and F for Model card example, link given in the Appendix).[2] A fillable model card template is also included in this paper's Appendix.[9]

What happens without it: In 2021, a study published in JAMA Internal Medicine independently evaluated a widely-deployed proprietary sepsis prediction model, then running at hundreds of US hospitals, against nearly 38,000 hospitalizations at a major academic medical center. The model failed to identify 67% of patients who developed sepsis, while generating alerts on 18% of all hospitalizations and producing substantial alert fatigue.[3] Real-world performance was far below the vendor's reported figures, and because the underlying model was proprietary, hospitals using it could not independently explain to their own clinicians how scores were generated or why specific patients were flagged. *The lesson: "the vendor says it works" is not an explanation. In clinical settings, the gap between vendor claims and auditable performance becomes a patient safety issue.*



Pillar 3 — Data Integrity & Lineage

The core question: Where did the data come from, how was it transformed, and is it fit for the purpose AI is being asked to serve?

Every AI system is shaped by the data it was trained on. If the training data is narrow, the outputs will be narrow. If it contains errors, the outputs will reflect those errors. If it was collected in one clinical context and applied to another, the system may behave in ways no one anticipated. In healthcare, this is not an abstract concern. A model trained on data from a single academic medical center may not generalize to a community hospital serving a different patient population. A model trained on historical claims data will inherit whatever biases and gaps that data contains. Data integrity means the organization knows what data an AI system was built

on, how that data was collected and transformed, and whether it is genuinely representative of the population and context it is being used for. Lineage means there is a traceable path from raw data to model output, documented clearly enough that a regulator, clinician, or board member can follow it.

What it looks like in practice: Every AI system has documented data lineage, a clear record of where the training data originated, how it was collected, what transformations were applied, and what populations it represents. There is a process for validating that the data used to train or fine-tune a model actually matches the patient population and clinical context it will be applied to. Consent boundaries are tracked: data that patients consented to share for treatment purposes is not silently repurposed for model training or analytics without review. When a regulator, a clinician, or a board member asks "where did this data come from?", the organization can answer within hours, not weeks, because the lineage is documented as a standard part of deployment, not reconstructed after the fact.

What happens without it: In 2018, internal IBM documents reviewed by STAT News revealed that IBM's Watson for Oncology, marketed as an AI capable of recommending cancer treatments and deployed at hospitals in multiple countries, had been trained largely on a small number of hypothetical patient cases authored by physicians at a single cancer center, rather than on the broad real-world patient data implied in the company's public messaging. Reviewers documented multiple examples of unsafe and incorrect treatment recommendations, and several hospitals subsequently discontinued use of the product.[4] The problem was not the algorithm itself; it was that the data it learned from did not match the patients it was being applied to. The lesson: an AI system is only as trustworthy as the provenance of its training data, and if you cannot trace that provenance, you cannot defend the tool's use.

Pillar 4 — Privacy & Security

The core question: How is data protected throughout the AI lifecycle?

Healthcare organizations are already experienced in protecting patient data. HIPAA, BAAs, encryption standards, and access controls are well-established. But AI introduces new data flows that existing privacy programs were not designed to cover. When a clinician uses an AI-powered documentation tool, patient data may leave the organization's network and travel to a vendor's servers, possibly through a subprocessor the organization has never evaluated. When a marketing team deploys an analytics tool with AI capabilities, it may collect and transmit patient information without anyone in IT or compliance knowing it exists. The AI lifecycle creates data exposure points that traditional security frameworks do not automatically address: data used for training, data processed during inference, data stored in model weights, and data shared with third parties through integrations that were never reviewed under HIPAA. Privacy and security in an AI context means extending existing protections to cover these new flows, not assuming they are already covered.

What it looks like in practice: Every AI system in production has a documented data flow, a clear map showing where data enters, where it is sent, where it is stored, who processes it, and whether any of it leaves the organization's control. This includes not just the primary vendor but their subprocessors: if your AI tool runs on a cloud platform that itself uses a third-party inference service, you know that and your BAA chain covers it. De-identification standards are defined and enforced before data reaches any AI system that does not require identified patient data. Access controls follow the principle of least privilege, meaning only the people and systems that need specific data to function have access to it, and that access is logged. There is a clear, tested answer to the question every CISO dreads: "when an employee pastes patient notes into an AI tool, where does that data go, who can see it, and is it being used to train the vendor's model?"

What happens without it: In 2022, a joint investigation by The Markup and STAT News found that roughly one-third of the top 100 hospitals in the United States had deployed a third-party tracking code on their public websites, and that several health systems had allowed it inside password-protected patient portals. The code quietly transmitted information about patient appointments, conditions, providers, and communications back to a major technology company. Two health systems alone disclosed resulting breaches affecting 1.3 million and 3 million patients respectively.[5] The tracking code had been added by marketing teams for analytics, not by IT or compliance, and no one had mapped where the data was flowing. Class actions and regulatory settlements followed. The lesson: you cannot protect data flows you have not documented. In AI and analytics systems, which routinely send data to vendors, subprocessors, and third-party servers, an undocumented flow is an undisclosed breach waiting to happen.

Pillar 5 — Fairness & Equity

The core question: Does the AI perform equitably across patient populations, geographies, and demographics?

Healthcare has a long and well-documented history of disparities in access, treatment, and outcomes. AI has the potential to reduce those disparities, but it also has the potential to deepen them, often invisibly. An algorithm does not need to include race as an input variable to produce racially biased outputs. It only needs to rely on proxy variables, such as zip code, insurance type, or historical healthcare spending, that correlate with race due to structural inequities already present in the system. The danger is not that someone deliberately builds a biased tool. The danger is that no one checks. In healthcare, an unchecked bias does not just produce an unfair outcome in the abstract. It means a patient who should have been flagged for additional care was not. It means a population that was already underserved is further deprioritized by a system that was supposed to be objective.

What it looks like in practice: Bias testing is a gating criterion for deployment, meaning no test, no go-live. Before any clinical AI system goes into production, it is evaluated for performance across demographic groups including race, ethnicity, gender, age, and socioeconomic proxies.

The organization defines what "equitable performance" means for each use case: not that outcomes must be identical across groups, but that the system does not systematically disadvantage one population relative to another due to training data gaps, proxy variables, or design assumptions that went unexamined. After deployment, the monitoring continues, because an AI system that tested fair on day one can drift as patient populations shift, clinical practices evolve, or referral patterns change. There is a defined threshold for what constitutes an unacceptable disparity, and when that threshold is crossed, it triggers review, not just a note in a quarterly report.

What happens without it: A landmark 2019 study published in Science examined a commercial risk-prediction algorithm applied to roughly 200 million Americans and used to identify patients for high-risk care management programs. The algorithm systematically under-identified Black patients as high-risk, because it used prior healthcare spending as a proxy for health needs, and less had historically been spent caring for Black patients at equivalent illness levels. Correcting the bias would have more than doubled the share of Black patients identified for additional care, from 17.7% to 46.5%.[6] The algorithm was not malicious; it was unexamined. *The lesson:* bias in healthcare AI is rarely introduced deliberately. It enters through proxy variables, training data gaps, and assumptions no one thought to question, and at scale, it compounds existing inequities.

Pillar 6 — Compliance & Auditability

The core question: Can you demonstrate governance to regulators, auditors, accreditation bodies, and your own board?

There is a meaningful difference between having governance and being able to prove it. Many healthcare organizations are doing reasonable work on AI oversight in practice: leaders are making thoughtful decisions, teams are evaluating tools before deployment, and risks are being weighed. But if that work is not documented, it does not exist in the eyes of a regulator. HIPAA, FDA, and state-level AI laws all require evidence, not intentions. When the HHS Office for Civil Rights investigates, they do not ask "did you think about risk?" They ask "show us your risk analysis." When the FDA reviews an AI-enabled medical device, they do not accept verbal assurance that validation was performed. They require documented evidence. Compliance and auditability means building the habit of generating that evidence as a natural part of how the governance program operates, so that when the question comes, the answer is already assembled.

What it looks like in practice: There is a current, maintained AI inventory, a living list of every AI system in use across the organization, including the data each system touches, the owner of each, the risk tier assigned, and the date of last review. For every system on that list, there is an approval record: who approved it, when, based on what review, with what conditions, and when it is due for re-review. Documentation is generated as a byproduct of normal operations. Approval workflows produce records, monitoring dashboards produce logs, committee meetings

produce minutes. It is not reconstructed during an audit-week scramble. The standard the organization holds itself to is straightforward: if the HHS Office for Civil Rights, the FDA, a state attorney general, or your own board asked tomorrow to see your AI governance documentation, you could hand them something coherent within 24 hours.

What happens without it: In October 2024, the HHS Office for Civil Rights launched a formal "Risk Analysis Initiative" after finding that across a pattern of investigations, healthcare organizations were consistently failing not at the incident itself but at the documentation. In settlement after settlement, the common finding was the same: the organization had "failed to conduct an accurate and thorough risk analysis," a foundational HIPAA Security Rule requirement. Within the initiative's first year, eight organizations reached settlements totaling nearly $900,000, each accompanied by multi-year corrective action plans.[7] The underlying breaches ranged from ransomware to exposed servers; the failure pattern was consistent. *The lesson: in regulated environments, undocumented governance is treated as no governance. The paper trail is the program.*

Pillar 7 — Continuous Monitoring & Lifecycle Management

The core question: How do you ensure AI systems remain safe and effective after deployment?

Most of the attention in AI governance focuses on the decision to deploy: the intake process, the risk assessment, the approval. But the risk profile of an AI system does not freeze at the moment of go-live. Patient populations change. Clinical protocols evolve. The data the model encounters in production may gradually diverge from the data it was trained on. Usage patterns shift as clinicians and staff find new ways to apply the tool, sometimes well beyond its original approved scope. A model that was accurate and fair on the day it launched can quietly degrade over weeks or months, and without active monitoring, no one notices until a clinician flags an anomaly, a patient is harmed, or an auditor asks a question the organization cannot answer. Continuous monitoring means treating deployment as the beginning of oversight, not the end.

What it looks like in practice: Every AI system in production is monitored on an ongoing basis, not just for uptime, but for performance, accuracy, usage patterns, and equity impact. There are defined metrics for each system and defined thresholds for what constitutes unacceptable drift: a clinical model whose sensitivity drops below a set level, an operational model whose error rate climbs beyond its validated range, a tool whose usage has expanded well beyond its approved scope. Monitoring is not passive. There are dashboards, alerting, and a named person responsible for reviewing each system on a cadence matched to its risk tier, with high-risk systems reviewed quarterly or more frequently and lower-risk systems annually. There is a retraining and revalidation process for models that have drifted, and critically, there is a sunsetting process for tools that have outlived their usefulness or fallen out of compliance. Retirement is planned, not discovered: the data is archived, dependencies are migrated, and the system is formally decommissioned rather than left running in the background, unwatched and collecting data.

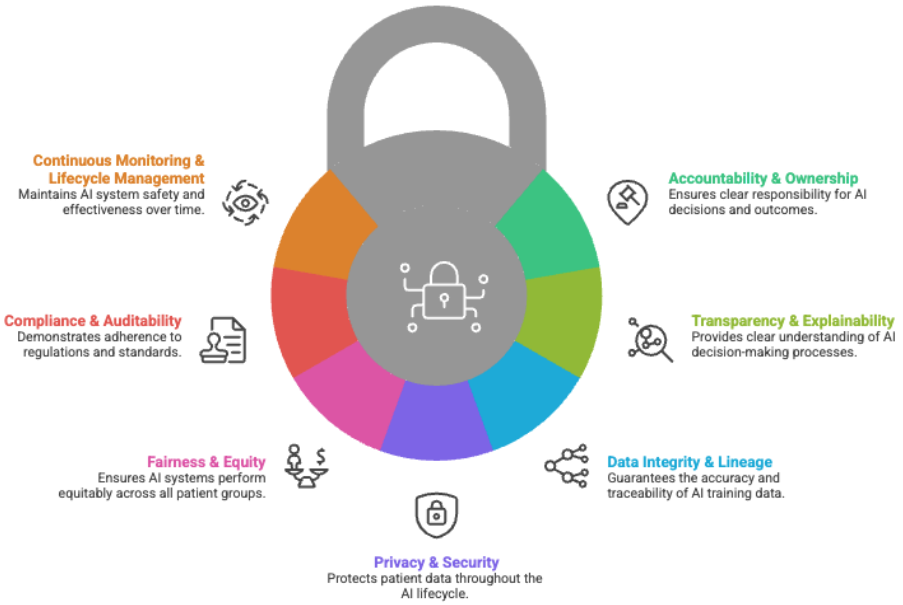
What happens without it: Early in the COVID-19 pandemic, many US hospitals turned to a proprietary clinical deterioration model, deployed at more than 100 health systems, to help identify patients at risk of decline. An independent evaluation published in 2021 found the model had low sensitivity for COVID-19 patients and performed meaningfully worse than on the non-pandemic population it had been developed for.[8] The model itself had not changed; the patient population had. Health systems without active monitoring had no way to catch the degradation in real time and were relying on a tool that no longer matched the clinical reality around it. The lesson: an AI system that was safe at deployment is not automatically safe a year later. Without active monitoring, drift is invisible, until a clinician, a patient, or a regulator notices first.

Why the Pillars Matter Together

Each pillar addresses a different dimension of risk and responsibility, but they are most effective when treated as one connected framework. Accountability without transparency creates blind spots. Transparency without data integrity creates false confidence. Privacy without ongoing monitoring leaves organizations exposed to misuse and drift. Fairness without documentation is difficult to defend. Compliance without clear ownership becomes a paperwork exercise rather than real governance.

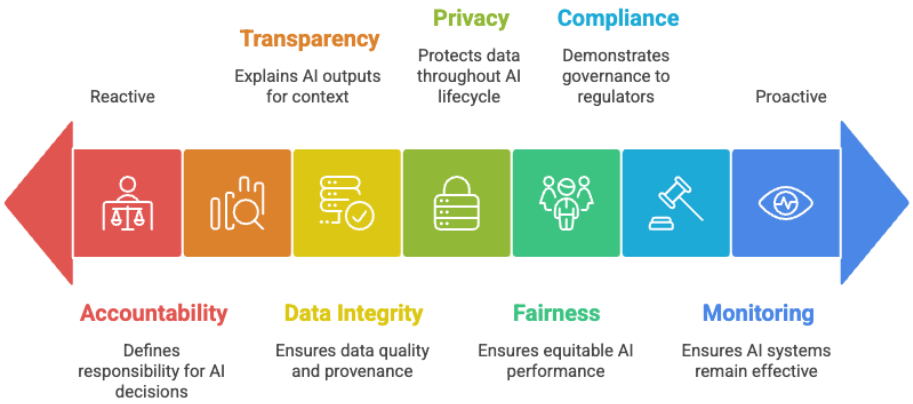
Together, these seven pillars help healthcare organizations move beyond ad hoc AI adoption and toward a disciplined, repeatable, and defensible approach. They give leaders a practical way to ask the right questions before a tool is deployed, while it is in use, and when it no longer meets the standard required.

Foundations of AI Governance



Made with Napkin

AI governance pillars range from reactive to proactive.



Made with Napkin

Glossary of Key AI, Data, and Healthcare Technology Terms

AI scribe / Ambient listening: AI that listens to a patient visit and drafts notes.

Machine Learning (ML): A type of AI that learns patterns from data.

Large Language Model (LLM): AI trained on lots of text to write, summarize, and answer questions.

Generative AI: AI that creates new content like text, notes, or images.

Model: The core part of an AI system that produces results.

Inference: When an AI model uses new data to give an output or answer.

Training data: The data used to teach an AI model.

Predictive model: A model that predicts what may happen next.

Clinical decision support (CDS): Tools that give clinicians alerts, scores, or suggestions.

Risk score: A score showing how likely a patient is to have a certain outcome.

Alert fatigue: When too many alerts make people start ignoring them.

Explainability: How clearly an AI system's output can be explained.

Model card: A short document explaining what a model does, where it should be used, and its limits.

Model drift: When a model becomes less accurate over time as real conditions change.

Bias / Algorithmic bias: When AI gives unfair results for some groups.

Bias testing: Checking whether an AI system works unfairly for certain groups.

Disparate impact: When a system affects one group worse than another, even if that was not intended.

Proxy variable: A data point used as a stand-in for something else.

Validation (external): Testing a model on different real-world data to see if it still works well.

Data lineage: Tracking where data came from and how it changed.

Subprocessor: A third party used by a vendor to help provide the service.

De-identification: Removing personal details so data cannot easily identify someone.

Shadow AI: AI tools employees use without approval or oversight.

AI inventory: A current list of AI tools being used in the organization.

Risk tiering: Grouping AI use cases by risk level, such as low, medium, or high.

Intake process: The formal way a new AI tool is submitted for review.

Sunsetting: Formally retiring an AI tool that is no longer needed or safe.

REFERENCES

1. Coldewey, D. "UK's MHRA says it has 'concerns' about Babylon Health — and flags legal gap around triage chatbots." *TechCrunch*, March 5, 2021. https://techcrunch.com/2021/03/05/uks-mhra-says-it-has-concerns-about-babylon-health-and-flags-legal-gap-around-triage-chatbots/. See also: "Medical Advice From a Bot: The Unproven Promise of Babylon Health." *Undark*, December 9, 2019.
2. Mitchell M, Wu S, Zaldivar A, et al. "Model Cards for Model Reporting." *ACM Conference on Fairness, Accountability, and Transparency*, 2019. See also: FDA. "Artificial Intelligence-Enabled Device Software Functions: Lifecycle Management and Marketing Submission Recommendations." Draft Guidance, January 7, 2025. Appendices E and F. https://www.fda.gov/media/184856/download.
3. Wong A, Otles E, Donnelly JP, et al. "External Validation of a Widely Implemented Proprietary Sepsis Prediction Model in Hospitalized Patients." *JAMA Internal Medicine*, 2021;181(8):1065–1070. doi:10.1001/jamainternmed.2021.2626.
4. Ross C, Swetlitz I. "IBM's Watson recommended 'unsafe and incorrect' cancer treatments, internal documents show." *STAT News*, July 25, 2018. https://www.statnews.com/2018/07/25/ibm-watson-recommended-unsafe-incorrect-treatments/.
5. Feathers T, Fondrie-Teitler S, Waller A, Mattu S. "Facebook Is Receiving Sensitive Medical Information from Hospital Websites." *The Markup*, June 16, 2022. See also: Novant Health and Advocate Aurora Health public breach notifications, 2022; HHS Office for Civil Rights. "Use of Online Tracking Technologies by HIPAA Covered Entities and Business Associates." Bulletin, December 2022.
6. Obermeyer Z, Powers B, Vogeli C, Mullainathan S. "Dissecting racial bias in an algorithm used to manage the health of populations." *Science*, 2019;366(6464):447–453. doi:10.1126/science.aax2342.

7. HHS Office for Civil Rights. "Risk Analysis Initiative." Launched October 31, 2024. See also: OCR Resolution Agreements for Bryan County Ambulance Authority, Elgon Information Systems, Northeast Radiology, Deer Oaks Behavioral Health, and others (2024–2025). https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/index.html.
8. Singh K, Valley TS, Tang S, et al. "Evaluating a Widely Implemented Proprietary Deterioration Index Model Among Hospitalized Patients with COVID-19." *Annals of the American Thoracic Society*, 2021;18(7):1129–1137. See also: Kamran F, et al. "Development and Validation of the COVID-19 Hospitalized Patient Deterioration Index." *American Journal of Managed Care*, 2022.
9. AI System Description (Model Card) - Sample and Template: A completed example and blank template are available for download at link.